

Aedis

The Agentic OS for Healthcare

Andrew Pearson · Ensign Group tech team · May 2026
goforit5.github.io/Aedis · andrew@taskvisory.com

Every SaaS is three things.

A database, a UI, and an API.

Agents don't need the UI. They talk to the data.

DATABASE

Where the truth lives

Postgres, SQL Server, proprietary stores. Resident records, GL, employee files.

UI

For human operators

Forms, dashboards, click-paths. Built for one user at a time.

API

For machines

REST, SOAP, FHIR, OData. Already there. Already governed by the vendor.

Aedis works at the API layer. The UI is for humans who need to [review](#) agent decisions, not [operate](#) the SaaS.

What Ensign runs today

Six surface areas, six API stacks.

SYSTEM	DOMAIN	INTEGRATION SURFACE	AUTH
PointClickCare	Clinical / EHR	FHIR R4 + proprietary REST	OAuth 2.0 (client credentials)
Workday	HR · Payroll · GL	REST + RaaS reports + WQL	OAuth 2.0 (tenant-scoped)
Microsoft 365	Mail · Calendar · Files	Graph API v1.0	Azure AD app reg + delegated/app perms
SharePoint	Documents · Policies	Graph + REST	Same Azure AD app
Internal SQL	Analytics · Custom	JDBC / ODBC / direct connect	SQL auth or Entra ID
CMS · OIG · SAM	Regulatory	Public REST	API key (free)

- ~ 330 facilities
- ~ 47 senior living communities
- 17 states
- All six are databases + UIs + APIs

Each connector implements the official SDK. No screen-scraping, no headless-browser puppeteering, no unsanctioned automation.

What changes

One control plane. Six APIs. Humans approve, not operate.

BEFORE

6 dashboards · N seats · M tabs

DON in PCC. Admin in Workday. Compliance in SharePoint. Switch context, lose context.

AFTER

1 control plane · 1 audit log

Agents read every system. Humans see one decision queue. Approve in < 10 seconds.

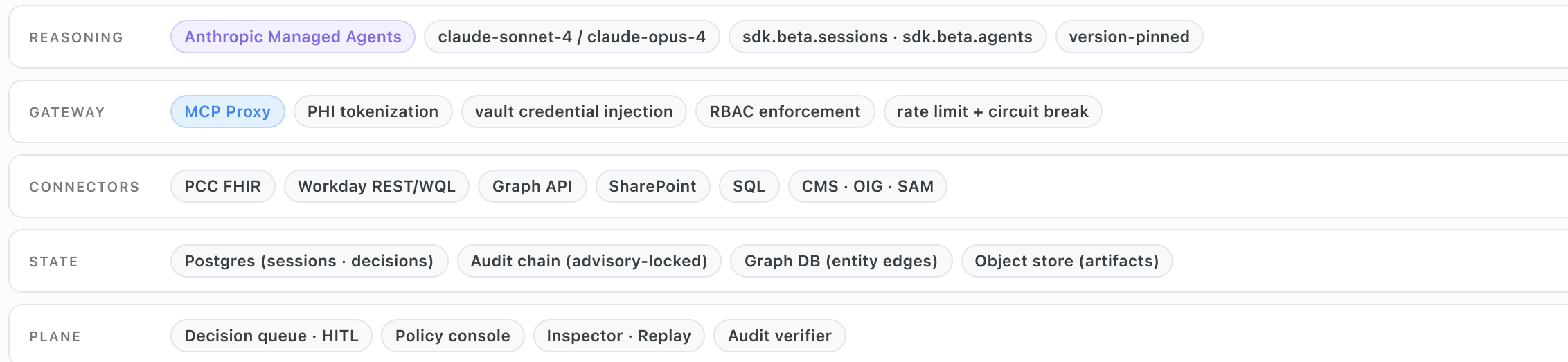
What humans still do

- **Approve** state-changing actions on a decision card with full context, evidence, and dollar/days impact
- **Escalate** when an agent's confidence is below threshold or two agents disagree
- **Govern** via policy console — set agent autonomy levels per facility, per domain, per action class
- **Audit** via tamper-evident chain — every read, every write, every prompt, every PHI token

The agent does the click-paths. The human owns the judgment call.

Architecture

Managed Agents → MCP gateway → connectors → enterprise APIs



SDK: official `@anthropic-ai/sdk` — never raw HTTP. Sessions stream via `sdk.beta.sessions.events.stream()`; cursor via `after_id`.

PHI handling

Phase 1 today · Phase 2 target · tokenized by default

Phase 1 — Today · Day 0 to ~120

- **Anthropic Managed Agents** under signed BAA
- **OCR and vision run inside the HIPAA boundary** (Zone 2); only tokenized output crosses to the agent
- **Tokenized at the MCP gateway** — names, MRNs, DOBs, rooms replaced with tenant-scoped HMAC tokens before any prompt is built
- Token vault lives in Ensign-controlled Postgres; tokens are session-scoped, tenant-scoped, key-versioned, no cross-session leakage
- Anthropic sees `resident_tok_7J4K9Q`, never [Margaret Chen](#)

Phase 2 — Target · Day ~120 onward

- **Bedrock-Managed-Agents** in Ensign's AWS VPC
- **PHI never leaves the VPC** — inference colocated with data
- Migration is a runtime swap, not a rewrite — same SDK surface
- Tokenization stays on as defense-in-depth (privacy-preserving by default)

6 Trust Zones

Where data lives, who can read it, what crosses the line

ZONE 1	Raw PHI Vault	scanned PDFs · DICOM · faxed orders · raw HL7/CDA	readers: vault service only	KMS CMK · VPC endpoint · no agent access
ZONE 2	HIPAA OCR / Vision	AWS Textract · Bedrock vision (in-VPC)	readers: ocr-service identity only	no prompt logging with raw PHI
ZONE 3	Token Vault	resident_tok ↔ raw_mrn map · HMAC(tenant, facility, src, mrn)	readers: rehydration service · break-glass auditor	key-versioned · TTL 24h · rotated on session close
ZONE 4	Tokenized Doc Store	OCR text + layout · tables · forms · confidence — PHI replaced with tokens	readers: any agent or human under RBAC	no raw names · no raw MRNs · no DOBs
ZONE 5	Agent Workspace	Managed Agents · Bedrock agents	readers: agent (tokenized-only) · server-enforced tool allowlist	prompts and tool calls cited in audit chain
ZONE 6	Rehydration + Audit Replay	tokens → cleartext for authorized humans only	readers: human under RBAC + purpose-of-use + MFA	every rehydration logged · replayable per decision

Zones 1–2 are the HIPAA boundary (raw PHI lives here, agents never enter). Zones 3–5 are tokenized-only. Zone 6 is where authorized humans see cleartext under audit.

HIPAA §164.502(b) minimum necessary · §164.308(a)(4) information access management · NIST SP 800-53 AC-3 · AC-6 least privilege · SC-28 protection at rest

Why OCR lives inside the PHI boundary

PHI is trapped in pixels until OCR runs

The naive design (wrong)

1. Upload scanned admission packet to S3
2. Hand the PDF to an LLM and "ask it to tokenize"
3. Trust the model to redact

Failure mode: the LLM has already **read** the PHI to redact it. PHI has crossed the boundary. There is no undo.

Aedis design (Zone 2)

1. Raw doc lands in Zone 1 vault — encrypted at rest, no agent reachable
2. **Inside the HIPAA boundary**, ocr-service calls AWS Textract (BAA-covered) for structured text + layout + tables + forms + confidence
3. Where confidence is low or vision is required (handwriting, signatures, stamps), **Bedrock vision runs in the same VPC** — no prompt logging that includes PHI
4. PHI scanner sweeps the OCR output, tokenizes detected entities, writes to Zone 4
5. Only the tokenized output (Zone 4) is visible to agents in Zone 5

Textract (BAA)

Bedrock vision (in-VPC)

PHI scanner: NAME · MRN · DOB · ADDR · PHONE · EMAIL · SSN · ACCT

Agent prompt contains zero raw PHI

HIPAA §164.312(a)(1) access control · §164.312(b) audit controls · §164.312(c)(1) integrity · AWS Textract HIPAA eligibility · Bedrock HIPAA eligibility

Tokenization, not de-identification

Precise compliance language

We do NOT claim

- HIPAA Safe Harbor de-identification under §164.514(b)(2)
- Expert Determination de-identification under §164.514(b)(1)
- "Bulletproof", "HIPAA-certified", or any superlative
- That tokenized data is outside the HIPAA Privacy Rule scope

We DO claim

- **Tokenization as an operational privacy control** — least-privilege, BAA-covered, auditable
- **Tenant-scoped HMAC tokens** — `HMAC_SHA256(tenant_secret, facility_id + source_system + raw_mrn)`
- Tokens are not reversible without rehydration service access (Zone 3 break-glass)
- Every rehydration is logged with actor, purpose-of-use, MFA factor, and decision context

For the record: "We do not claim de-identification under HIPAA. We use tokenization as our operational privacy control. De-identification is a separate compliance determination we have not pursued."

[HIPAA §164.514\(a\)–\(b\) de-identification standards](#) · [§164.502\(d\) de-identification permitted uses](#) · [NIST SP 800–188 de-identification guidance](#) · [OCR FAQ on de-identification](#)

Two AI modes

Tokenized-text by default · PHI-bound vision on escalation

Mode A — Tokenized-text agent (default)

- Runs in Zone 5 (Anthropic Managed Agents under BAA in Phase 1; Bedrock in-VPC in Phase 2)
- Input: tokenized OCR output from Zone 4 — zero raw PHI
- Output: tokenized decision proposal with cited evidence tokens
- Use cases: AP coding, invoice reconciliation, claim appeal drafting, schedule analysis, policy lookup
- **~95% of decisions resolve here**

Mode B — PHI-bound vision agent (escalation)

- Runs **inside the HIPAA boundary** (Bedrock vision in-VPC under BAA)
- Input: raw document pixels from Zone 1 (signature blocks, handwriting, stamps, complex layouts)
- No prompt logging that includes PHI · output tokenized before return to Zone 5
- Use cases: signature verification, handwritten progress notes, ID badge OCR fallback, complex form vision
- **Escalation only · always dual-approval HITL · governance level 5**

The agent doesn't choose its mode. The confidence router does — see next slide.

HIPAA §164.312(a)(1) access control · §164.312(b) audit controls · §164.502(b) minimum necessary · Bedrock HIPAA eligibility · Anthropic BAA

Confidence routing

Green deterministic · Yellow tokenized LLM · Red PHI-bound vision

Green — deterministic

`textract.confidence > 0.95` · schema validates · no PHI ambiguity

- Auto-tokenize, hand to Mode A
- Single-approval HITL · governance level 4
- Audit row written, downstream agents notified

Yellow — tokenized LLM

`0.80 ≤ confidence ≤ 0.95` · schema partial · ambiguous entities

- Mode A normalizer (tokenized text only)
- Single-approval HITL with normalizer trace
- If normalizer fails twice → escalate to red

Red — PHI-bound vision

`confidence < 0.80` · signature / handwriting / human request

- Mode B vision (in-VPC, no PHI logging)
- Dual-approval HITL · governance level 5
- Auditor co-signs · full chain replayable

The router itself is deterministic and inspectable in the audit chain. No model decides whether PHI escapes the boundary — policy does.

HIPAA §164.312(a)(1) access control · §164.308(a)(4) information access management · NIST SP 800-53 AC-3 · §164.312(b) audit controls

Live demo · Patient Safety toggle

Margaret Chen → resident_tok_7J4K9Q

What the human sees

PHI · cleartext

Margaret Chen · Bayview · Rm 247

MRN 18477392 · DOB 1948-03-14 · POA Susan Chen

What the agent sees

tokenized

resident_tok_7J4K9Q · facility_tok_BV ·

room_tok_247

mrn_tok_B8Z1P2 · dob_tok_3FD9A1 ·

poa_tok_44KQ8L

The decision recommendation reads identically in both modes. The agent's prompt contained zero raw PHI to begin with – the toggle just changes what the human reviewer sees.

Live demo · Audit Replay

6-zone swimlane for Decision D-4822

ZONE 1	raw_doc.received	actor: vault-service	sha256: 9a7c...b2e1	size: 312 KB · pages: 4
ZONE 2	ocr.extracted	actor: ocr-service	phi_entities: {NAME:2, MRN:1, DOB:1}	policy: tokpol_2026_05
ZONE 3	tokens.created	resident_tok_7J4K9Q · mrn_tok_B8Z1P2 · dob_tok_3FD9A1	key_version: v3	
ZONE 4	tokenized_doc.stored	doc_id: tdoc_4F2A · contains zero raw PHI		
ZONE 5	agent.prompt_built	agent: ClinicalMonitor-v12	prompt_sha256: 4c1d...8a92	tools_called: search_tokenized_invoices, propose_appeal_draft
ZONE 6	human.rehydrated	actor: don-bayview · MFA: webauthn	purpose: appeal_review · minimum_necessary: true	egress: workday.expense_create (tokenized)

Every row above is a real audit event with a content hash linking to the previous row. The chain is monotonically ordered, advisory-locked per tenant, and verifier-replayable end-to-end.

Live demo · Agent Inspector — Tool Permissions

The agent has no tool that can leak PHI

Allowed tools (Clinical Monitor)

- `search_tokenized_invoices`
- `compare_invoice_to_contract`
- `propose_gl_code`
- `request_rehydration_for_human_review`
- `draft_appeal_letter` (tokenized output)

Forbidden tools (server-enforced)

- `display_mrn`
- `display_patient_name`
- `read_phi_vault`
- `decrypt_raw_document`
- `egress_to_unscoped_endpoint`

Enforcement lives in the MCP gateway, not the agent. The agent literally has no path to the forbidden tools – they are not registered in its session manifest.

HIPAA §164.308(a)(4) information access management · §164.312(a)(1) access control · NIST SP 800-53 AC-6 least privilege · AC-3 access enforcement

Human-in-the-loop governance

Every state-changing action is paused, gated, and logged.

The flow

1. Agent identifies action requiring approval (Medicare appeal, PCC care plan update, Workday timecard adjustment)
2. Session enters `requires_action` — Aedis treats this as **paused**, not terminal. Cursor preserved via `after_id`.
3. Decision card materializes: full context, evidence, recommendation, confidence score, dollar/days impact
4. Human approves (Enter), escalates (E), or defers (D). Single keystroke. RBAC checked.
5. SDK receives `user.tool_confirmation`. Session resumes from `session.status_idle`.
6. Audit row written, hash chain extended, downstream agents notified via event cascade

Decision card

CRITICAL

Bayview · Rm 247

\$8,420

Submit Medicare A appeal — Margaret Chen denial
CMS reason 5J: insufficient skilled-need
documentation. Appeal window closes in 11 days. PT
notes 11/12, 11/14, 11/15 support skilled need; agent
confidence 94%.

approve · ↵

escalate · E

defer · D

HIPAA §164.312(a)(1) access control · §164.308(a)(4) information access management · NIST SP 800-53 AC-3 · AC-6 least privilege

Audit chain

Tamper-evident, monotonically ordered, advisory-locked.

Schema (intended)

```
CREATE TABLE audit_event (
  sequence_number BIGINT GENERATED ALWAYS AS IDENTITY,
  tenant_id       UUID          NOT NULL,
  occurred_at     TIMESTAMPTZ   NOT NULL DEFAULT now(),
  actor_type      TEXT          NOT NULL, -- 'agent'|'human'|'system'
  actor_id        TEXT          NOT NULL,
  event_type      TEXT          NOT NULL,
  resource_ref    TEXT,         -- e.g. 'pcc:resident:12345'
  payload         JSONB         NOT NULL,
  previous_hash   BYTEA         NOT NULL,
  content_hash    BYTEA         NOT NULL,
  PRIMARY KEY (sequence_number)
);
```

Write protocol

1. Acquire pg advisory lock on `hashtext(tenant_id)` — serializes writes per tenant
2. Read tail `content_hash`; compute `content_hash = sha256(prev || canonical(row))`
3. Insert; identity column assigns `sequence_number` atomically
4. Release lock; publish to event bus

Verifier

- Walk chain head-to-tail, recompute each `content_hash`
- Mismatch → tamper alert, page on-call, freeze tenant
- Daily attestation; verifier signature persisted

HIPAA §164.312(b) audit controls · §164.312(c)(1) integrity · 21 CFR Part 11 §11.10(e) audit trails · NIST SP 800-66r2 audit

Identity & RBAC

Azure Entra ID, per-facility scope, kill switches.

Authentication

- **Azure Entra ID JWKS** (RS256) · 6-hour key cache · auto-rotate on verify failure
- `JWT_SECRET` HS256 fallback service-to-service only — never exposed to humans
- Dev fallback removed; WebSocket upgrades require `?token=` query param
- Audience: `aedis://ensign` · Issuer: Ensign's Entra tenant

Authorization

- 5 base roles: **CEO · Admin · DON · Billing · Accounting**. Extensible.
- JWT claims: `roles[]`, `facility_ids[]`, `scope[]`. Connector calls scoped per facility.
- Read-only / auditor users **cannot** hit escalate, defer, or trigger endpoints
- Decision approvals require role match — checked server-side, not by the UI

PAUSE ONE AGENT

< 30 seconds

In-flight sessions transition to `paused`; queue stops draining.

PAUSE FACILITY

< 30 seconds

Per-facility scope freezes all agent activity for that `facility_id`.

GLOBAL KILL

< 30 seconds

Tenant-level pause; sessions drain to checkpoint.

HIPAA §164.308(a)(4) access management · §164.312(a)(1) access control · §164.312(a)(2)(iii) automatic logoff · NIST SP 800-63B AAL2

Vault-and-proxy

Agents never see raw credentials. Ever.

Storage & rotation

- **AWS Secrets Manager** at `snf/{tenant}/{credential}`
- Per-credential KMS key, customer-managed
- **90-day automated rotation** via Lambda — dual-key overlap so ops never break
- CloudWatch alarms on rotation failure; on-call paged
- Production refuses env-based secrets; `--source=env` is dev only

Request flow

1. Agent calls MCP tool with **no** credential field
2. Proxy authenticates JWT (RS256), looks up tenant + credential
3. Proxy fetches secret (cached 5min, KMS-decrypted) and makes upstream call
4. Response returned to agent — credential never crosses the agent boundary
5. Audit row written — secret never logged or echoed

Emergency revocation

Detect

CloudWatch alarm · manual trigger · Sentry

Revoke

emergency-revoke.ts · scrubs Secrets Manager · invalidates cache

Reissue

Terraform reprovision · < 15 min end-to-end

HIPAA §164.312(a)(2)(i) unique user ID · §164.308(a)(5)(ii)(D) password mgmt · NIST SP 800-57 key mgmt · NIST SP 800-53 IA-5

Compliance posture

What's signed, what's in flight, what's roadmap.

ITEM	STATUS	ETA	NOTES
HIPAA BAA — Anthropic	Signed	Today	Covers Phase 1 Managed Agents. Available on request.
HIPAA BAA — AWS	Template ready	Day 0	Standard AWS BAA, executed during Phase 2 VPC provisioning.
HIPAA BAA — Aedis ↔ Ensign	Drafted	Day 0	To execute at engagement kickoff. Reviewed by HIPAA counsel.
SOC 2 Type 1	In flight	Day 90	Auditor selected, controls scoped, evidence pipeline live.
SOC 2 Type 2	Roadmap	Day 365	Requires 6–12 month observation window post-Type 1.
HITRUST CSF r2	Roadmap	Year 2	Path mapped, prerequisites in SOC 2 controls.
NIST SP 800-66r2	Aligned	Today	Risk assessment & controls mapped to HIPAA Security Rule.
Privacy Policy / ToS	Published	Today	aedis.health (target) · current at goforit5.github.io/Aedis
Token lifecycle policy	Codified	Today	Session-scoped · 24h TTL · tenant-HMAC derivation · KMS key versioning · rotated on session close
Role-based evidence visibility	Codified	Today	Agents see tokens always · humans see per RBAC + purpose-of-use + MFA · both paths audited

HIPAA Security Rule §164.306–§164.318 · HHS audit protocol · AICPA TSC 2017 · NIST SP 800-66r2

Engagement model

30-day wire-up · scale on signal · 6-month nationwide exclusivity.

Day 0 — 30 · me, hands on

- Stand up MCP gateway in dev VPC
- Wire **PCC** (FHIR + REST) — residents, vitals, care plans, MAR
- Wire **Workday** (REST + WQL) — workers, time, GL, benefits
- Wire **M365** (Graph) — mail, calendar, SharePoint policies
- Deploy 1 pilot facility with HITL gates and 6 starter agents
- Daily demo · weekly architecture review

Day 30 — 180 · small team scales it

- Add **5–6 senior AI engineers** (frontend, backend, infra, ML)
- Domain by domain: Clinical → Finance → Workforce → Quality → Operations
- Phase 2 migration to Bedrock-Managed-Agents in Ensign VPC
- Roll out 10 → 50 → 330 facilities on telemetry-driven cadence
- SOC 2 Type 1 audit complete by Day 90

EXCLUSIVITY

6 months nationwide SNF exclusivity

In exchange for engagement signing + credential handoff. After window, market opens — Ensign keeps a permanent preferred-pricing tier and roadmap influence.

The ask is not "approve this in committee for six months." It's "sign an LOI this week, hand over credentials, watch us wire it."

What we need from Ensign

Five decisions. Five days to deploy.

#	WHAT	OWNER	DOC
1	PCC OAuth client — client ID + secret, redirect URI, scopes. We need read on residents, vitals, care plans, MAR; write on care plan updates and progress notes (gated by HITL).	Ensign IT + PCC vendor	<code>platform/docs/credential-registration/pcc-registration.md</code>
2	Workday tenant — tenant URL, OAuth client, integration system user (ISU). Read on workers, time, GL; write on timecard adjustments (HITL gated).	Ensign HRIS	<code>workday-registration.md</code>
3	M365 Azure AD app registration — client ID + cert, Graph permissions: Mail.Read, Calendars.ReadWrite, Sites.Read.All, Files.Read.All. Tenant admin consent.	Ensign Azure admin	<code>m365-registration.md</code> · Terraform module ready
4	AWS account access — sandbox account for Phase 1, production VPC subnet for Phase 2 Bedrock deployment. We supply CloudFormation; you control the account.	Ensign Cloud Ops	Phase 2 only — Day ~90
5	BAAs executed — Aedis ↔ Ensign, AWS ↔ Ensign (Phase 2). Anthropic BAA already covers Phase 1 via Aedis.	Ensign Legal	Drafts shared with engagement letter

With these five in hand, the wire-up is a matter of days, not months. No ABMS approvals, no committee tour — just a handoff and a working pilot.

Questions.

Andrew Pearson · andrew@taskvisory.com

Demo (current): goforit5.github.io/Aedis

Demo (target post-DNS): aedis.health

Repo: [goforit5/Aedis](https://github.com/goforit5/Aedis) (private) · CTO pack: [goforit5/aedis-pitch-deck](https://github.com/goforit5/aedis-pitch-deck) (private)